

EXPLOITED VULNERABILITY ADVISORY: CVE-2026-59822

Summary

CVE-2026-59822 in BerriAI LiteLLM is being actively exploited in the wild. LiteLLM is a proxy server (AI Gateway) to call LLM APIs in OpenAI (or native) format. Prior to 1.84.0, LiteLLM's MCP Streamable HTTP endpoint allowed an unauthenticated attacker to use a fabricated Authorization header to trigger an OAuth2 passthrough fallback path that replaced failed LiteLLM key validation with an empty UserAPIKeyAuth() object, allowing requests to reach MCP tooling without a valid LiteLLM key. This issue is fixed in version 1.84.0. CISA requires federal remediation by 2026-09-16; under the CRA, exploitation of an affected product must be reported within 24 hours.

What we know

- **CVE:** CVE-2026-59822
- **Affected:** BerriAI LiteLLM
- **Exploitation:** Actively exploited, added to CISA KEV on 2026-09-02
- **Severity:** CVSS 8.2 High, Network-exploitable, no privileges required, no user interaction (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N)
- **Exploitation likelihood (EPSS):** 1%
- **Seen in our tracked reporting:** 1 campaign(s), incl. activity attributed to Qilin
- **Weakness:** CWE-287, CWE-306

Recommended action

Patch CVE-2026-59822 by 2026-09-16. If you cannot patch immediately, restrict network access to the affected service now (segment it, put it behind a VPN, or take it offline) until you can patch. If you ship an affected product, be ready to file the CRA 24-hour report the moment you find it exploited.

Sources: CISA Known Exploited Vulnerabilities, NIST NVD, and Salamander's own corpus. Public data; an advisory of active exploitation, not an incident report. Verify applicability to your estate before acting.